

Индивидуальный проект

Этап 2

Карпова Есения Алексеевна

Содержание

1	Цель работы	1
2	Задание.....	1
3	Теоретическое введение	1
4	Выполнение лабораторной работы	2
5	Выводы.....	9

1 Цель работы

Приобретение практических навыков по установке DVWA.

2 Задание

Установить DVWA на дистрибутив Kali Linux.

3 Теоретическое введение

В данной лабораторной работе будет осуществлена установка Damn Vulnerable Web Application (DVWA) на гостевую систему Kali Linux. DVWA представляет собой учебное веб-приложение, созданное для практики в области безопасности веб-приложений. Оно содержит множество преднамеренно внедренных уязвимостей, что делает его идеальным инструментом для изучения и тестирования методов атаки и защиты.

Ключевыми уязвимостями, которые содержатся в DVWA, являются: брутфорс – метод подбора паролей с целью демонстрации слабости пользователей; выполнение команд (инъекции) – доступ к командной строке операционной системы через веб-приложение; межсайтовая подделка запроса (CSRF) – уязвимость, позволяющая изменить настройки пользователей без их ведома; внедрение файлов – возможность загрузки несанкционированных файлов на сервер; SQL-инъекция – позволяющая внедрять SQL-запросы в поля ввода; небезопасная выгрузка файлов – открытие возможности для загрузки вредоносных файлов; межсайтовый скриптинг (XSS) –

внедрение пользовательских скриптов в приложение; а также другие уязвимости, такие как раскрытие полных путей и обход аутентификации.

DVWA предлагает три уровня безопасности, которые позволяют пользователю на практике увидеть, как уязвимости могут быть использованы в реальных сценариях. На уровне “Невозможный” происходит демонстрация безопасного кода и позволяет сравнить его с уязвимым. Уровень “Высокий” представляет собой комбинацию более сложных безопасных и небезопасных практик, где уязвимости ограничены. Уровень “Средний” показывает примеры плохих практик безопасности и неудачных попыток разработчиков создать безопасное приложение. Наконец, уровень “Низкий” полностью уязвим и предназначен для обучения основам эксплуатации.

4 Выполнение лабораторной работы

Настройка DVWA происходит на нашем локальном хосте, поэтому нужно перейти в директорию `/var/www/html` (рис. 1).

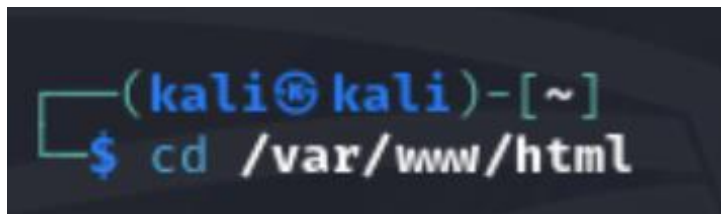


Рис. 1: Директория `/var/www/html`

Клонирую нужный репозиторий GitHub (рис. 2).

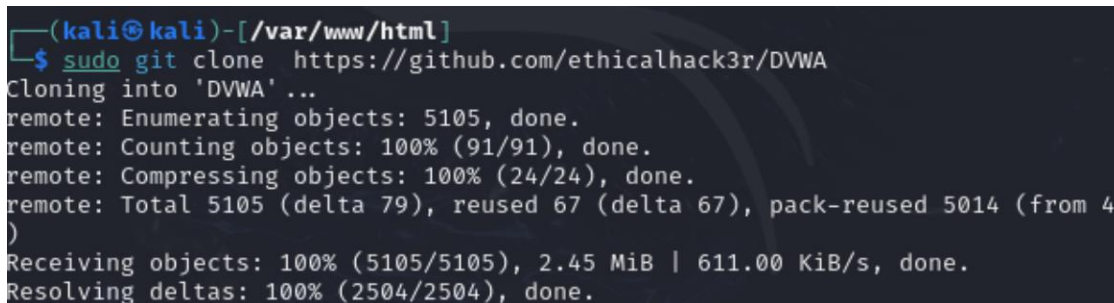


Рис. 2: Клонирование репозитория

Проверяю, что файлы скопировались правильно, далее повышаю права доступа к этой папке до 777 (рис. 3).

```
(kali㉿kali)-[/var/www/html]
$ ls
DVWA  index.html  index.nginx-debian.html

(kali㉿kali)-[/var/www/html]
$ sudo chmod -R 777 DVWA
```

Рис. 3: Изменение прав доступа

Чтобы настроить DVWA, нужно перейти в каталог `/dvwa/config`, затем проверяю содержимое каталога (рис. 4).

```
(kali㉿kali)-[/var/www/html]
$ cd DVWA/config

(kali㉿kali)-[/var/www/html/DVWA/config]
$ ls
config.inc.php.dist
```

Рис. 4: Перемещение по директориям

Создаем копию файла, используемого для настройки DVWA `config.inc.php.dist` с именем `config.inc.php`. Копируем файл, чтобы у нас был запасной вариант, если что-то пойдет не так (рис. 5).

```
(kali㉿kali)-[/var/www/html/DVWA/config]
$ sudo cp config.inc.php.dist config.inc.php

(kali㉿kali)-[/var/www/html/DVWA/config]
$ ls
config.inc.php  config.inc.php.dist
```

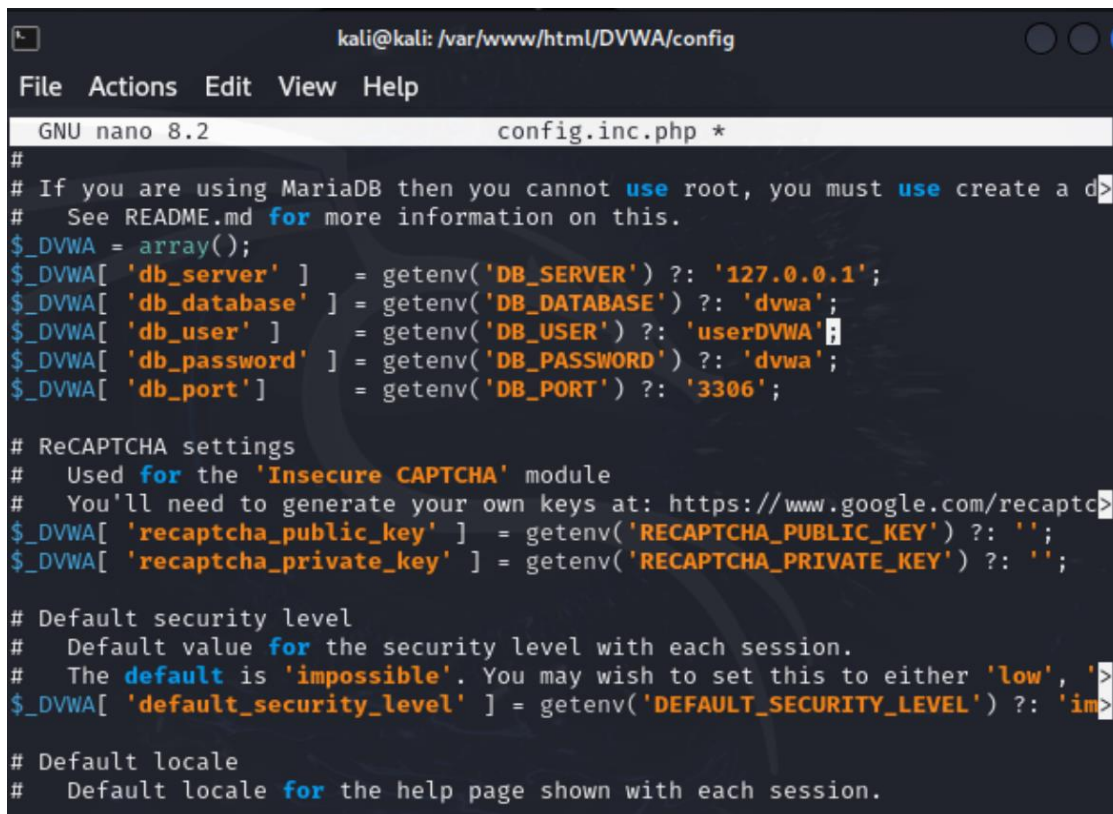
Рис. 5: Создание копии файла

Далее открываю файл в текстовом редакторе (рис. 6).

```
(kali@kali)-[/var/www/html/DVWA/config]
$ sudo nano config.inc.php
```

Рис. 6: Открытие файла в редакторе

Изменяю данные об имени пользователя и пароле (рис. 7).



```
kali@kali: /var/www/html/DVWA/config
File Actions Edit View Help
GNU nano 8.2 config.inc.php *
#
# If you are using MariaDB then you cannot use root, you must use create a d
# See README.md for more information on this.
$_DVWA = array();
$_DVWA[ 'db_server' ] = getenv('DB_SERVER') ?: '127.0.0.1';
$_DVWA[ 'db_database' ] = getenv('DB_DATABASE') ?: 'dvwa';
$_DVWA[ 'db_user' ] = getenv('DB_USER') ?: 'userDVWA';
$_DVWA[ 'db_password' ] = getenv('DB_PASSWORD') ?: 'dvwa';
$_DVWA[ 'db_port' ] = getenv('DB_PORT') ?: '3306';

# ReCAPTCHA settings
# Used for the 'Insecure CAPTCHA' module
# You'll need to generate your own keys at: https://www.google.com/recaptc
$_DVWA[ 'recaptcha_public_key' ] = getenv('RECAPTCHA_PUBLIC_KEY') ?: '';
$_DVWA[ 'recaptcha_private_key' ] = getenv('RECAPTCHA_PRIVATE_KEY') ?: '';

# Default security level
# Default value for the security level with each session.
# The default is 'impossible'. You may wish to set this to either 'low', '>
$_DVWA[ 'default_security_level' ] = getenv('DEFAULT_SECURITY_LEVEL') ?: 'im>

# Default locale
# Default locale for the help page shown with each session.
```

Рис. 7: Редактирование файл

По умолчанию в Kali Linux установлен mysql, поэтому можно его запустить без предварительного скачивания, далее выполняю проверку, запущен ли процесс (рис. 8).

```
(kali㉿kali)-[/var/www/html/DVWA/config]
$ sudo systemctl start mysql

(kali㉿kali)-[/var/www/html/DVWA/config]
$ systemctl status mysql
● mariadb.service - MariaDB 11.4.3 database server
   Loaded: loaded (/usr/lib/systemd/system/mariadb.service; disabled; pres>
   Active: active (running) since Sat 2025-03-15 05:19:13 EDT; 11s ago
  Invocation: 6e448550999a40f9ba3f89e6d0488310
     Docs: man:mariadb(8)
           https://mariadb.com/kb/en/library/systemd/
   Process: 21438 ExecStartPre=/usr/bin/install -m 755 -o mysql -g root -d >
   Process: 21445 ExecStartPre=/bin/sh -c systemctl unset-environment _WSRE>
   Process: 21458 ExecStartPre=/bin/sh -c [ ! -e /usr/bin/galera_recovery ]>
   Process: 21596 ExecStartPost=/bin/sh -c systemctl unset-environment _WSR>
   Process: 21598 ExecStartPost=/etc/mysql/debian-start (code=exited, statu>
  Main PID: 21542 (mariadb)
    Status: "Taking your SQL requests now ..."
     Tasks: 14 (limit: 14651)
    Memory: 215.9M (peak: 220.2M)
       CPU: 1.923s
    CGroup: /system.slice/mariadb.service
            └─21542 /usr/sbin/mariadb
```

Рис. 8: Запуск mysql

Авторизируюсь в базе данных от имени пользователя root. Появляется командная строка с приглашением "MariaDB", далее создаем в ней нового пользователя, используя учетные данные из файла config.inc.php. Затем предоставляем привилегии для работы с этой базой данных (рис. 9).

```
create user 'userDVWA'@'127.0.0.1' identified by "dvwa" at line 3
MariaDB [(none)]> create user 'userDVWA'@'127.0.0.1' identified by "dvwa";
Query OK, 0 rows affected (0.009 sec)

MariaDB [(none)]> grant all privileges on dvwa.* to 'userDVWA'@'127.0.0.1' id
entified by 'dvwa';
Query OK, 0 rows affected (0.003 sec)

MariaDB [(none)]> exit;
Bye
```

Рис. 9: Авторизация в базе данных

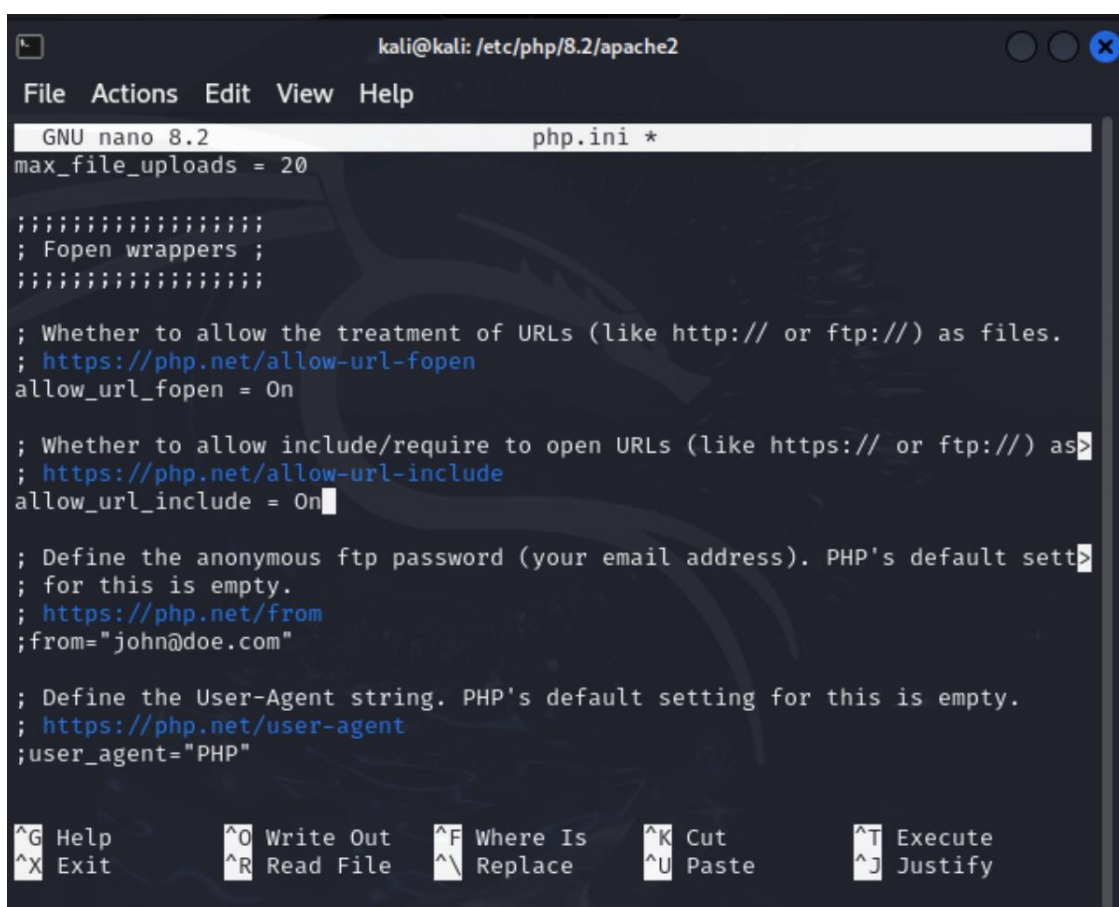
Необходимо настроить сервер apache2, перехожу в соответствующую директорию. В файле php.ini нужно будет изменить один параметр, поэтому открываю файл в текстовом редакторе (рис. 10).

```
(kali@kali)-[/var/www/html/DVWA/config]
$ cd /etc/php/8.2/apache2

(kali@kali)-[/etc/php/8.2/apache2]
$ sudo nano php.ini
```

Рис. 10: Открытие файла в текстовом редакторе

В файле параметры `allow_url_fopen` и `allow_url_include` должны быть поставлены как `On` (рис. 11).



```
kali@kali: /etc/php/8.2/apache2
File Actions Edit View Help
GNU nano 8.2 php.ini *
max_file_uploads = 20

;;;;;;;;;;;;;;;;
; Fopen wrappers ;
;;;;;;;;;;;;;;;;

; Whether to allow the treatment of URLs (like http:// or ftp://) as files.
; https://php.net/allow-url-fopen
allow_url_fopen = On

; Whether to allow include/require to open URLs (like https:// or ftp://) as
; https://php.net/allow-url-include
allow_url_include = On

; Define the anonymous ftp password (your email address). PHP's default sett
; for this is empty.
; https://php.net/from
;from="john@doe.com"

; Define the User-Agent string. PHP's default setting for this is empty.
; https://php.net/user-agent
;user_agent="PHP"

^G Help      ^O Write Out  ^F Where Is   ^K Cut        ^T Execute
^X Exit      ^R Read File  ^\ Replace    ^U Paste      ^J Justify
```

Рис. 11: Редактирование файла

Запускаем службу веб-сервера apache и проверяем, запущена ли служба (рис. 12).

```
(kali㉿kali)-[/etc/php/8.2/apache2]
$ sudo systemctl start apache2

(kali㉿kali)-[/etc/php/8.2/apache2]
$ systemctl status start apache2
Unit start.service could not be found.
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; disabled; pres>
   Active: active (running) since Sat 2025-03-15 05:36:17 EDT; 4s ago
 Invocation: 0ddc53fde7b1407a8aafa513a6362947
    Docs: https://httpd.apache.org/docs/2.4/
   Process: 29929 ExecStart=/usr/sbin/apachectl start (code=exited, status=>
 Main PID: 29953 (apache2)
    Tasks: 6 (limit: 2219)
   Memory: 19.9M (peak: 20.1M)
      CPU: 100ms
   CGroup: /system.slice/apache2.service
           └─29953 /usr/sbin/apache2 -k start
             └─29956 /usr/sbin/apache2 -k start
               └─29957 /usr/sbin/apache2 -k start
                 └─29958 /usr/sbin/apache2 -k start
                   └─29959 /usr/sbin/apache2 -k start
                     └─29960 /usr/sbin/apache2 -k start

Mar 15 05:36:17 kali systemd[1]: Starting apache2.service - The Apache HTTP >
```

Рис. 12: Запуск apache

Мы настроили DVWA, Apache и базу данных, поэтому открываем браузер и запускаем веб-приложение, введя 127.0.0/DVWA (рис. 13).

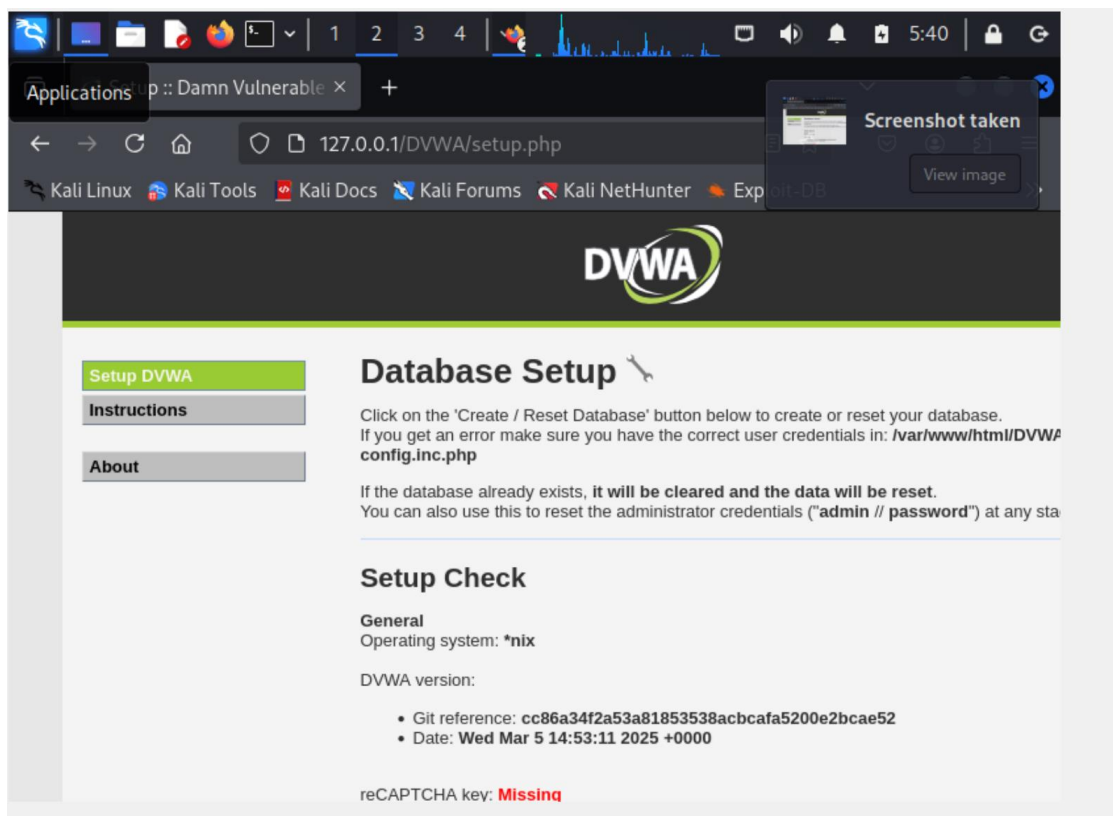


Рис. 13: Запуск веб-приложения

Прокручиваем страницу вниз и нажимаем на кнопку create\reset database. Авторизуюсь с помощью предложенных по умолчанию данных. Оказываюсь на домашней странице веб-приложения, на этом установка окончена (рис. 14).

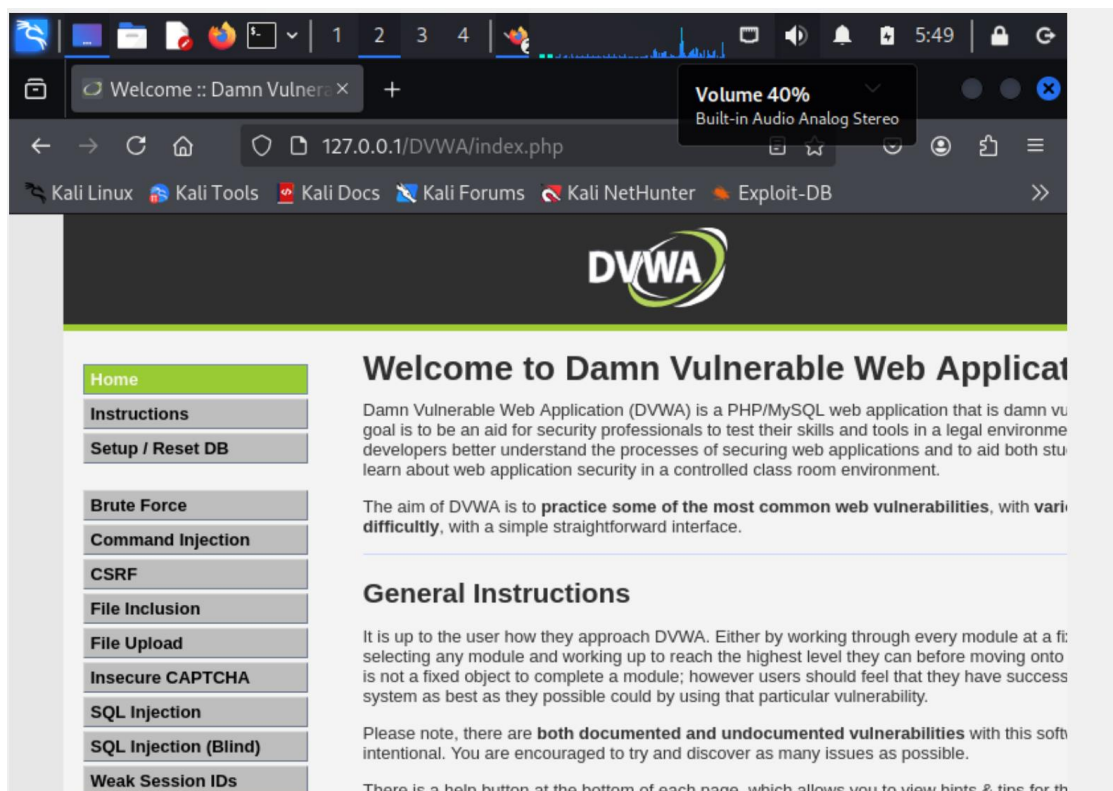


Рис. 14: Создание базы данных

5 Выводы

В ходе выполнения лабораторной работы я приобрела практические навыки по установке уязвимого веб-приложения DVWA.